Udyam Digital — privacy & security note

A privacy-first prototype built around consent, purpose limitation and data minimisation, in the spirit of India's DPDP Act, 2023. It does **not** claim legal compliance or certification — that needs a formal review. All business records here are synthetic (the case's dataset); the live demo used the team's own phone and Aadhaar with consent.

WHAT WE COLLECT, WHY, AND FOR HOW LONG

Data	Purpose	Required?	Kept
Phone number (SMS OTP)	Account, quote, order, signing, updates	To buy	Contract term; erased on delete
Business profile, site address, pincode	Plan, feasibility (India Post), installation	To buy	Contract term
GSTIN / Udyam number	Registry lookup first, so fewer uploads	If declared	Masked fields for contract + statutory period
Uploaded documents	KYC: read fields, check legibility	Only what's missing	**File never stored** — read in memory; extracted fields + SHA-256 only
DigiLocker / Aadhaar offline e-KYC	Fetch instead of upload	Optional, own consent	Name, address, state, pincode, last 4 digits, birth year — nothing else; token never stored
Bill photo	Compare current spend	Optional	Photo never stored; the amount only
Support requests, chats	Answer questions; context for an agent	Optional	Erased on delete; staff see masked context
Offers & product updates	Marketing	Optional, **off by default**	Until withdrawn

CONSENT AND THE OWNER'S RIGHTS

- **Consent before collection, enforced in code.** KYC APIs return 403 without a recorded KYC consent; DigiLocker has its own optional purpose; WhatsApp/Telegram updates need the "service" purpose. Each receipt stores id, notice version, purposes and time.
- **Purpose-bound codes.** A login OTP can never sign an order; a signing code is bound to the SHA-256 of the exact PDF shown.
- **Minimal sharing.** Share links show plan and price only — no phone, GSTIN or address. A CA uploads through a delegate link without an account and sees nothing else.
- **Access, export, erase.** Account → "Your data & privacy": download everything as JSON, or delete the account in one tap (profile, businesses, chats, plans, KYC, consent, support). Orders are contract records and are kept anonymised.

AI BOUNDARIES

- Gemini (paid API, server-side) gets the owner's words and, after KYC consent, the document pages — never the phone number. Prompts aren't used for model training under Google's paid-tier terms.
- AI output is untrusted input: facts are schema- and range-checked, intents whitelisted, and any number the rules engine didn't produce gets the reply discarded. Price, eligibility and KYC verdicts are deterministic code.

SECURITY CONTROLS

- **Fail closed.** No key → the service refuses (503) instead of pretending: OTP, payments, document reading, channels, DigiLocker. Test shortcuts exist only behind `ALLOW_TEST_VERIFY=1`, never in production.
- **Verifiable money and signatures.** Razorpay signatures HMAC-checked and the payment re-read (order, exact amount, status). Signed order forms carry the PDF hash, time, masked phone and IP.
- **Authenticated webhooks.** Meta `X-Hub-Signature-256`, Twilio signature, Telegram secret token — constant-time compare, retries de-duplicated.
- **Access control.** Ops roles enforced server-side and audit-logged; forged staff cookies are refused; tracking links are unguessable tokens; sales credit only from a signed-in staff session.
- **Abuse limits.** OTP: 30 s cooldown, 4 sends/hour, 5 attempts, 5-minute expiry, single use. Chat: 12 messages/minute.
- **Masking.** GSTIN, Udyam, phone and ID numbers masked in UI and logs; logs never hold message text, phone numbers or tokens.
- **Hosting.** Vercel functions pinned to Mumbai (bom1); keys live only in server environment variables; database is Turso (libSQL).

Known gaps (honest list) before production: field-level encryption at rest for KYC fields and phone numbers (KMS); an automated retention/purge job (today's daily cron only sends reminders and flags stuck orders); a formal DPIA and DPDP legal review; IP-level rate limiting at the edge; Aadhaar eSign through a licensed ASP (today: IT-Act e-signature, OTP-bound and hashed); live GST/Udyam APIs instead of the supplied registries.